Assessment 01: Security foundations

NAME	Utthan Bhat
BATCH / GROUP	EWB AI-Powered Cybersecurity Internship
COURSE	AI-Powered Cybersecurity
DATE	07/11/2026

Task A: Secure a student account

A1 (10 marks)

C, I and A mean confidentiality, integrity and availability.

Risk	Asset	CIA impact	Control	Limitation
1. Password reuse (email and portal)	Email account, portal account, linked identity	C: one stolen password exposes both. I: email access allows messages and password resets. A: lockout or suspension.	A unique passphrase per account in a reputable password manager, so one leak stays contained.	Master password becomes a single point of failure; real-time phishing can still steal passwords.
2. Approving unexpected MFA prompts (MFA fatigue: repeated prompts until the user taps approve)	Portal account, authenticated session	C: private data exposed. I: actions taken in the session. A: account locked during investigation.	Number matching, passkeys or security keys, and never approving prompts I did not start; these resist accidental approval and phishing.	Not every service supports them; session-token theft can bypass MFA.
3. Postponed device updates	Laptop, cached credentials, stored files	C: unpatched flaws expose files. I: malware modifies files. A: ransomware or instability.	Automatic security updates and prompt reboots, which remove known vulnerabilities.	Zero-day flaws remain; updates can break compatibility.
4. Only one project copy	Project files	A: failure, loss or theft removes the project. I: the only copy may become corrupted.	3-2-1 backups (three copies, two media, one offsite) with version history, enabling restoration.	Costs effort and storage; restores must be tested; ransomware can encrypt connected backups.

Risk	Asset	CIA impact	Control	Limitation
5. Friend using Mira's signed-in laptop	Mira's account, active session, accessible data	C: friend sees private data. I: files changed under Mira's identity. Accountability (not a CIA element): actions cannot be reliably attributed.	Separate standard or guest account, screen lock and session timeout, which limit access and improve accountability.	Shared physical access is hard to control; the friend could still install malware.

A2 (10 marks)

Controls, reasons and limitations are in the table. My first three actions, in order, are: fix password reuse, improve MFA habits (moving to phishing-resistant MFA where available), then set up reliable backups [1].

Password reuse is first because the exposure is broad (one leak opens two accounts) and the fix is low effort. MFA is second: with a known password, repeated prompts are the likely next step, so safer MFA addresses a likely harm. Backups are third because they take more effort and guard against loss rather than intrusion, but losing the only project copy has severe impact. Updates and separate laptop accounts remain important and should follow soon.

A3 (5 marks)

Authentication proves who a user is. In the learning portal, Mira enters her username and password and then completes MFA, answering "Are you Mira?" Authorisation decides what that authenticated identity may do. A student role may view its own grades but not edit them, open another student's records or use administrator pages. Least privilege grants only the access a role needs, so signing in never gives unlimited access.

Authentication failure: someone enters a wrong password or fails MFA, so no session should be created. Authorisation failure: a correctly signed-in student reads another student's grades or gets administrator rights.

Task B: Analyse a suspicious message

B1 (10 marks)

This analysis assesses the supplied text only. A warning sign is not proof of malice. (The brief asks for five signs; six are listed to show distinct issues.)

Relevant quoted phrase	Why it requires scrutiny
`Scholarship Desk <awards@campus-awards.example>`	The college normally uses campus.example; campus-awards.example is a look-alike. A display name is freely chosen text and authenticates nothing.
`Reply-To: help@personal-awards.example`	Replies go to an unrelated domain, not a monitored college mailbox, diverting the conversation.
`FINAL WARNING - scholarship expires in 20 minutes`	Manufactured urgency discourages careful verification.
`enter your college password and OTP`	An unsolicited link asking for both is highly suspicious. An OTP typed into a login I started myself is normal; disclosing it through a message or unverified page is not.
`Do not contact the college office because their system is unavailable`	Isolates the recipient from independent verification and is a classic social-engineering tactic.
`Reply with a photo of your identity card to speed up payment`	Harvests identity documents usable for impersonation and fraud, and applies a payment-bait incentive.

B2 (5 marks)

Verify using independently obtained information [1]:

1. Ignore the link and any address or number in the message.
2. Type the portal address manually or use a saved bookmark.
3. Check the handbook, intranet or official notices.
4. Phone the scholarship office using a number from an independently verified official source.
5. Log in directly and inspect the scholarship or fees section.
6. If unsure, forward the message as an attachment to college IT/security; do not reply.

HTTPS encrypts traffic in transit. A valid certificate shows a protected connection to a domain, not a trustworthy organisation, and look-alike domains can obtain certificates. A display name is sender-chosen text. SPF, DKIM and DMARC results add email-authentication evidence but are not absolute proof. A padlock does not mean safe.

B3 (7 marks)

If the password and OTP were already entered:

1. **Containment**, from a known-clean device: change the portal password and any reused one, email first if shared, since email access enables resets. Sign out all sessions, revoke tokens, remove

unknown MFA methods and re-register MFA; changing only the password may leave an attacker's session active. Restrict the account temporarily if activity continues.

2. **Reporting**: tell college IT and the scholarship office through official contacts, preserve the original email with headers, report it as phishing and follow any national-authority procedure.
3. **Follow-up**: review sign-in history, forwarding rules, recovery details, profile changes and unexpected resets; watch for targeted phishing; report identity-document exposure; record times and actions.

Never send a password or OTP to support staff; they do not need them.

B4 (3 marks)

The message alone cannot establish who controls the sender, its SPF, DKIM or DMARC results, or whether the linked site is malicious or a copycat. Useful evidence: full headers, domain registration data, reports from other students and college IT analysis. The sender cannot be called a criminal from this text.

Task C: Triage a sign-in alert

C1 (8 marks)

All times are IST on 18 October 2026. Authentication logs record events, not necessarily the person at the keyboard. The student's statement is reported information, not a verified log event.

1. **Normal classroom sign-in.** Observed: 09:00 password success and 09:01 MFA approval from `192.0.2.10`. Interpretation: consistent with a normal sign-in, because the source matches the documented classroom egress and the student says they signed in before 09:05.
2. **Password failures, then success.** Observed: 10:14 and 10:15 password failures, then 10:16 success, all from `198.51.100.23`. Interpretation: consistent with someone eventually entering the correct password after two failures. The source differs from the usual egress, but a different IP alone does not show an outsider, and the logs do not show who entered the password or how it was obtained.
3. **MFA activity and session.** Observed: 10:17 MFA denied, 10:18 MFA approved and 10:20 session created, all from `198.51.100.23`. Interpretation: repeated prompts followed by approval are consistent with MFA fatigue (push bombing). The student says they approved a prompt to stop the requests, so the approval may have been theirs even though they did not knowingly start the sign-in.
4. **Student statement.** Observed: student07 states they did not sign in after 09:05 and approved a prompt around 10:18 to stop repeated requests. Interpretation: a session was created after the time the student says they stopped signing in, and they do not describe starting it. This is the strongest reason to suspect an unauthorised session.

C2 (7 marks)

Likely explanation. A third party knew or guessed the password and triggered repeated MFA prompts. The student approved one out of fatigue, which allowed the session created at 10:20. This is consistent with the evidence but not proven.

Alternative explanation. The student may have signed in from another device or network, such as a phone on mobile data, a VPN or another campus egress, and not remember it. Their own retries or a synchronisation problem could explain the repeated prompts. This cannot be dismissed without further evidence.

Two additional checks.

1. **Device and authentication evidence.** Inspect the device ID, user-agent, MFA method and origin, and other details for the 10:16-10:20 events. Compare them with student07's known devices and ask about their device use. A match with a known device would favour the alternative explanation.
2. **Source correlation and session activity.** Search the wider authentication log for `198.51.100.23` across other accounts. Failures against many usernames would support credential guessing, though they would still not identify anyone. Also inspect the 10:20 session for mailbox rules, forwarding changes, data access and account-settings changes.

IP attribution caveat. An IP address is not a person. It can represent a shared NAT, campus proxy, VPN exit or mobile carrier address, and it may be reassigned. The records support the statement that a session was created from `198.51.100.23`. They do not prove that a named person used that address, stole the password or performed the sign-in.

C3 (6 marks)

Three prioritised actions for the authorised IT team:

1. **Contain the account.** Revoke active sessions and tokens, force a password reset, re-register MFA, remove unknown MFA methods and devices, and restrict the account temporarily if suspicious activity continues. *Why:* the immediate concern is a possibly active authenticated session, and containing it limits further unauthorised access.
2. **Preserve evidence.** Export the relevant authentication logs and the session-activity records for the affected window, record hashes and a basic chain-of-custody note, keep the originals intact and never delete or edit suspicious records. *Why:* logs are perishable evidence that support investigation, reporting and accountability. This is coordinated with containment so that protecting the account does not lose available evidence.
3. **Investigate and harden.** Review actions in the 10:20 session, check other accounts for activity from the same source, and block or rate-limit that source only if policy and evidence justify it, since shared infrastructure may be involved. Enable number matching or phishing-resistant MFA and give user-awareness guidance. *Why:* this shows the impact of the session and reduces the chance of recurrence.

Order: containment is first because the session may still be live. Preservation follows immediately because records may expire or change. Wider investigation and hardening come last, to establish impact and prevent recurrence.

C4 (4 marks)

At 09:00 student07 signed in normally from the usual classroom egress, 192.0.2.10. From 198.51.100.23 there were two failed password attempts and one success at 10:14-10:16, then an MFA denial, an approval at 10:18 and a session at 10:20. The student says they did not sign in after 09:05 and approved a prompt to stop repeated requests. The evidence supports concern about an unauthorised session but does not identify a person. Priority: high. Next actions: revoke sessions and preserve logs.

Task D: Review an AI security answer

D1 (10 marks)

#	Claim in the AI output	What is wrong	Corrected advice	Reason and evidence
1	"The email is safe because it uses HTTPS."	HTTPS shows encryption, not legitimacy.	Check the sender domain, authentication results and independently obtained official contacts before trusting it [1].	HTTPS encrypts traffic in transit, and look-alike domains can obtain valid certificates. The message already shows a domain mismatch (campus-awards.example against campus.example) and a different Reply-To.
2	"The sign-in logs prove that the person using 198.51.100.23 stole the password."	Logs record events and an address, not a person or how a password was obtained.	Say only: "The logs show that a session was created from 198.51.100.23." Attribute it to no one.	An IP can be shared NAT, a proxy, a VPN exit or a mobile carrier address, and may be reassigned. The scenario states a different IP alone is not proof of an attacker.
3	"MFA prevents every account compromise."	MFA greatly reduces risk but guarantees nothing.	Use number matching or phishing-resistant MFA and never approve unexpected prompts.	MFA can be bypassed by push bombing, real-time phishing proxies, session-token theft, SIM swapping or help-desk social engineering. The logs show an MFA denial then an approval at 10:18.
4	"Delete the suspicious logs."	Deletion destroys evidence, weakens the investigation and reporting, and may breach retention or legal duties.	Preserve and export the relevant logs, record hashes and keep a chain-of-custody note.	The logs are the only record of what happened between 10:14 and 10:20.
5	"send the student's password to support so they can test it."	Passwords and OTPs must never be sent to anyone, including support.	Reset the affected password, revoke sessions, review MFA methods and follow the official incident process.	Support does not need the secret to investigate, and sharing it widens the breach. Passwords and OTPs must not appear in any report.

The AI output gives dangerous instructions, not only technical errors: following claims 4 and 5 would destroy evidence and expose a secret. NIST's Generative AI Profile [2] covers confabulation, where a model states false content confidently, which is why a human must verify AI-generated security advice before acting on it.

D2 (5 marks)

A reusable prompt that keeps the AI inside the synthetic evidence:

```
Role: You are a cautious cybersecurity analyst helping a student with a training
exercise.

Scope: Use only the fictional scholarship email and synthetic sign-in log rows supplied
below. Do not search for the domains, visit URLs, contact anyone, or access any real
system. Do not infer a person's identity from an IP address. Do not ask for, store,
repeat or transmit any password, OTP, token, or personal information. The evidence is
synthetic, no real student data is included and no live investigation is authorised.

Rules:
- Separate observed facts from interpretation.
- Give a confidence level (high, medium or low) for every important conclusion.
- Recommend only defensive, proportionate steps that an authorised person can verify.
- Give a reference for each technical claim, or say that you have none.

Output: four short sections headed Facts, Interpretation, Uncertainty and Next steps.

Evidence (the only evidence you may use):
Email - From: Scholarship Desk <awards@campus-awards.example>; Reply-To: help@personal-
awards.example; Subject: FINAL WARNING - scholarship expires in 20 minutes. Body: Your
scholarship has been approved. Open https://campus-awards.example/verify immediately
and enter your college password and OTP to avoid cancellation. Do not contact the
college office because their system is unavailable. Reply with a photo of your identity
card to speed up payment.
Log (18 October 2026, IST; the usual classroom egress is 192.0.2.10):
09:00 student07 192.0.2.10 Password Success
09:01 student07 192.0.2.10 MFA Approved
10:14 student07 198.51.100.23 Password Failed
10:15 student07 198.51.100.23 Password Failed
10:16 student07 198.51.100.23 Password Success
10:17 student07 198.51.100.23 MFA Denied
10:18 student07 198.51.100.23 MFA Approved
10:20 student07 198.51.100.23 Session Created
Student statement: "I did not sign in after 09:05. At around 10:18, I approved a prompt
because I thought it would stop the repeated requests."
```

D3 (6 marks)

If a message demands urgent action and asks for my login details, I treat it as hostile until I have checked it another way. I never type my password and OTP into a page reached from an unsolicited link. I open the portal from a bookmark or typed address and contact the college using details I found myself. If I have already submitted my details, I change my password from a clean device, sign out every session, set up MFA again and report it to the college. I approve an MFA prompt only when I started that sign-in. I keep my devices updated, use a different password for each account and keep tested backups. HTTPS and a familiar sender name do not show who really sent a message or whether the organisation is genuine.

D4 (4 marks)

AI-use declaration. AI tools used: ChatGPT (for structured prompt generation and report organisation) and Claude (for initial drafting of Task A-D answers). Purpose: report structure, first-draft wording and clarity review. I reviewed every technical claim against the supplied references (CISA Secure Our World and NIST AI 600-1), rewrote the prioritisation reasoning in A2 and the personal security advice in D3 in my own words, and take full responsibility for the final content. No real student data was entered. Date: 07/11/2026.

Reference note 1: CISA, "Secure Our World" [1]. This is the supplied CISA resource for basic account security and phishing awareness. I use it as general support for recognising and reporting phishing, unique passwords, MFA and software updates, where its guidance applies.

Reference note 2: NIST, "Generative AI Profile, NIST AI 600-1" [2]. This resource supports recognising possible confabulation and verifying AI-generated information instead of trusting it automatically. I use it in D1 to support the critique of the fictional AI output and the need for human verification.

References

1. Cybersecurity and Infrastructure Security Agency (CISA), "Secure Our World."
   https://www.cisa.gov/secure-our-world
2. National Institute of Standards and Technology (NIST), "Generative AI Profile, NIST AI 600-1."
   https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

AI-use declaration

> The complete AI-use declaration, naming every tool used and stating the purpose, together with the two supporting reference notes, appears in **Task D4** above. No real student data was entered at any stage.

End of report. Total: 4 tasks, 15 sub-questions, 100 marks.